

I built a security gate

A tiny FastAPI app.
Four checks before merge.

LIVE ON GITHUB

4 / 4 checks passed on main

BUILD LOG

The first CI run failed.

I found the issue in the test command.

GITHUB ACTIONS / CI

```
ModuleNotFoundError:  
No module named 'app'
```

I added pytest.ini.
The next run passed.

A small API, tested end to end.

7 passing tests / input validation / safe note IDs

GET

/health

Health response: 200 OK

POST

/notes

Create a note with validated fields

GET

/notes/{note_id}

Read it back by ID

```
GET /health -> {"status":"healthy"}
```

```
POST /notes -> 201 Created, id=1
```

THE APP

Every PR runs four checks.

Each job has a clear pass or fail result.

01

CI + SBOM

Tests pass and a component inventory is uploaded.

02

Gitleaks

Looks for committed secrets.

03

CodeQL

Scans Python code for security findings.

04

Trivy

Blocks medium or higher dependency findings.

The audit found a vulnerable pytest.

The original range selected an affected release.

BEFORE

pytest 8.4.2

CVE-2025-71176

AFTER

pytest 9.1.1 pinned

I raised the minimum version,
then reran pip-audit and Trivy.

A REAL FINDING

The build lists its components.

CycloneDX 1.6 SBOM uploaded by CI.

29

components in the
GitHub runner artifact

sbom-cdx-json

Downloadable from the passing CI run

Passing runs protect main.

The GitHub ruleset enforces the path to merge.

- 1 Open a pull request
- 2 Pass four required checks
- 3 Clear CodeQL alert threshold
- 4 Merge; force pushes blocked

ENFORCEMENT

What shipped

Verified on GitHub, 5 October 2026

4

required workflow
checks

7

passing API
tests

1

CycloneDX 1.6
SBOM artifact

0

open code scanning
alerts at validation

AT A GLANCE

Explore the source and runs.

The code, failed run, fix,
passing checks, and SBOM
are all public.

GITHUB

`github.com/TRahman2414/
day-01-devsecops-security-gate`

Built to be inspected, not just watched.

OPEN SOURCE